FDE SCENARIO DRILLS #01

FDE SCENARIO DRILLS · ISSUE 01 OF 08

The email that gave the agent orders.

Scenario: an inbox agent forwards a contract to an outside address.

01

AR

Akhilesh Ranjan Singh
Senior DevSecOps Engineer · github.com/iarsingh

Swipe →

First hour

01 Contain

Disable the send tool with a flag. Keep reading and drafting.

02 Scope

Search tool-call logs for every external send this week.

03 Tell the customer

Security contact first, with facts, not guesses.

04 Preserve evidence

Prompt, retrieved content, tool calls, timestamps.

AR
Akhilesh Ranjan Singh
github.com/iarsingh

ROOT CAUSE

The model treated data as instructions.

No prompt fully prevents that. The fix is what the agent is allowed to do.

AR
Akhilesh Ranjan Singh
github.com/iarsingh

The design change

BEFORE

- Send tool always available
- Any recipient allowed
- Email text mixed into instructions
- No approval step

AFTER

- Drafts only by default
- Recipient allowlist in code
- Untrusted content clearly marked
- Human approves external sends

AR
Akhilesh Ranjan Singh
github.com/iarsingh

Prove it is fixed

01 **Red-team set**

Hidden instructions in email, PDF and web content.

02 **Eval in CI**

Injection cases must never call a write tool.

03 **Alert**

On any blocked external send attempt.

AR
Akhilesh Ranjan Singh
github.com/iarsingh

What interviewers listen for

- [x] Contain before you debug
- [x] Customer told early
- [x] Fix in architecture, not prompt
- [x] Least-privilege tools
- [x] Evidence the fix holds

AR
Akhilesh Ranjan Singh
github.com/iarsingh

KEY TAKEAWAY

Limit what injected text can do, not just what it can say.

→ Turn off the risky tool first

→ Treat retrieved content as untrusted

→ Approval gates for writes and sends

YOUR TURN

How would you test an agent for indirect prompt injection?

FOLLOW AKHILESH RANJAN SINGH

Next in the series: #02 Forty pods, zero database connections

Save · Repost

AR
Akhilesh Ranjan Singh
github.com/iarsingh